SAFARI ZANGU VENTURES

Implementation & Remediation Report

What the September 2026 Enterprise System Audit found, what has since been built or fixed, and what remains open — reconciled item by item.

---

20 September 2026

Prepared as a direct reconciliation against the September 2026 Enterprise System Audit

Executive Summary

Following the Enterprise System Audit (Audit_Report.pdf and its companion documents, all dated 20 September 2026), a remediation pass addressed every one of the audit's seven finding categories: the Quotation Engine, Operations Management, Business Workflow, Code Quality, Database, Performance & Known Bugs, and Security. This report reconciles that work against the original findings — what closed, what's partial, and what was deliberately left open, with the reasoning for each. Nothing below is asserted without a corresponding code change, a live test, or an explicit decision recorded at the time.

70%	39	7	10
FINDINGS FULLY CLOSED	DONE	PARTIAL	OPEN / DEFERRED

56 individually tracked findings across the seven categories. 39 fully closed, 7 partially addressed (with the specific gap named in each case), and 10 left open — 6 of those deliberately, matching the original audit's own severity assessment (e.g. caching and dashboard query batching were rated “not urgent at current data volume” and remain genuinely not urgent); the other 4 are either infrastructure-level (encryption at rest) or a business decision that isn't the codebase's to make (see “Items That Are Your Call” at the end of this report).

Verification approach

Every “DONE” item in this report was verified live against real data during the work — not just read back from code. That included: rendering the affected page or endpoint under a real admin session and checking for zero PHP warnings; for pricing changes, running the calculation against real database rows and confirming the dollar figures moved the way the fix intended; for cross-language logic (the season-detection code that exists in both PHP and the admin quotation builder's JavaScript), extracting the actual deployed JavaScript and running it under Node against the PHP output, not comparing hand-retyped copies of the logic; and for every piece of test data created during verification, confirming it was deleted afterward. Where a fix could not be verified this way — for example, features gated behind data an admin has not yet entered, such as resident park-fee rates that are still $0.00 on file — that is stated explicitly rather than implied to be working.

1. Quotation Engine

The original audit's single largest finding was two parallel pricing engines, one of them dead code with no callers. That was resolved first, and the remainder of this section's items follow directly from consolidating onto the one live engine, App\Services\ItineraryQuoteBuilder.

Finding	Status	Detail
Two parallel pricing engines (one dead code)	DONE	App\Services\QuotationEngine.php deleted along with its only entry point (api/quote.php), confirmed zero callers first. Its one genuinely useful piece — detectSeason() — was ported into the live engine, not discarded.

Finding	Status	Detail
Seasonal pricing not applied to any live quote	DONE	Wired into accommodation and vehicle costing. Verified live: identical trip priced $1,174.10 in peak season vs $1,010.38 in low season.
Resident/EAC park-fee pricing not applied	DONE	Wired and live, but dormant — park_fees.resident_adult/resident_child are still $0.00 on every row, so it has no effect on real quotes yet. Falls back safely to the standard rate rather than charging $0 for a resident. Will activate the moment real rates are entered in Park Fees.
Single supplement never charged	DONE	Solo-traveler bookings now get an extra accommodation line from accommodations.single_supplement. Scoped to adults=1 only — the itinerary schema has no per-room occupancy data to safely detect a lone traveler within a larger party.
Child pricing only applied to park fees	DONE	accommodations.child_rate now applied as a per-child-per-night line. Verified live: 2 children × $70 × 1 night = $140 exactly.
Airport/ground transfer “is this per-traveler” guess	DONE	Was a name-substring heuristic (did the label contain the word “transfer”). Replaced with an explicit checkbox on every itinerary cost row, in both admin builders. Old saved data without the new field still falls back to the original heuristic, so nothing already saved silently changed.
Fuel and driver costs bundled into one vehicle line	DONE	Vehicle costs now itemize into separate Daily Rate / Fuel / Driver Allowance lines when a day's rate matches the vehicle's on-file components exactly. Verified with a real split ($300 + $50 + $50 = $380 test case). All 4 real vehicles on file currently have $0 fuel/driver components, so this has no visible effect yet — same dormant-until-data-entered pattern as resident pricing.
park_fees.vehicle_fee — referenced but never existed	DONE	This was a live, confirmed bug: quotation_new.php's park-fee autocomplete silently returned empty because its SELECT referenced a column that didn't exist. Added the real column (Tanzania parks do charge a separate per-vehicle entry fee) — fixes the bug and adds the missing pricing category in one change.
No markup/margin step in the live calculation	DONE	Added an explicit, optional markup percentage to the totals calculation (subtotal → markup → discount → VAT). Defaults to 0% — no price changes unless an admin actively sets one. 4 new tests cover the math, including markup-before-discount ordering.
VAT_RATE constant defined but not read	DONE	The live calculator hardcoded the literal 0.18 instead of the config constant. Now reads VAT_RATE — same value today, one fewer place a future rate change could be missed.

Finding	Status	Detail
Client-side JS preview drifted from server truth	DONE	A direct consequence of the pricing changes above: the admin's live preview didn't know about season/resident/single-supplement/child pricing, so it would show one number and save a different one. Fully synced in both admin quotation builders, plus an automated test (see Code Quality).
Accommodation costing is a flat room rate, not per-person	PARTIAL	Unchanged — this is the existing per-room-per-night model, not a bug introduced or fixed here. Layering true per-person costing on top would need a room-occupancy model the itinerary schema doesn't have; noted as a real limitation rather than worked around with a guess.
Multi-currency — USD only, no real conversion	PARTIAL	Built as real, admin-managed, display-only infrastructure (a currency_rates table replacing one hardcoded GBP constant). Bookings, quotations and actual charges all still settle in USD — accepting real payment in a foreign currency is a payment-gateway and settlement decision with real financial risk, and wasn't taken without it being asked for specifically.
Concession/community fees have no dedicated line	OPEN	Achievable today via the existing free-text “Other Costs” field on any itinerary day (the same mechanism transfers used before this fix) — not a revenue-accuracy gap, just not a first-class field. Left alone rather than building new schema for something the existing mechanism already covers.
Guide cost has no distinct line item	OPEN	Still bundled into the flat “Professional Driver Guide & Service Fee” line, unchanged. Guide/driver now exist as real, assignable personnel (see Operations Management) — but that's an operations concept, not a separate pricing line, and the two weren't conflated.
No dynamic/demand-based pricing	OPEN	Not addressed — not requested, and no occupancy/lead-time data exists anywhere in the schema to base it on.

2. Operations Management

Scored 3.0/10 in the original audit — the largest gap versus an enterprise DMC platform, with every one of its 9 capabilities confirmed missing or partial. All 9 are now built.

Capability	Status	What was built
Supplier/contract management	DONE	New suppliers table, admin CRUD, linked directly to individual accommodations records rather than a disconnected directory.
Guide assignment	DONE	New staff table modeling the business's actual single guide-driver role (not invented separate roles), assignable per booking.

Capability	Status	What was built
Vehicle assignment / conflict detection	PARTIAL	Same-day conflict-blocking verified live (a second assignment attempt on the same date is correctly rejected). Not a full date-range overlap detector for multi-day trips.
Driver assignment	DONE	Covered by the same guide-driver staff model above.
Room/inventory availability tracking	DONE	Confirmed 100% missing in the original audit. New optional available_rooms allotment per accommodation; a new service computes real room commitments from actual booking itineraries (not a separate reservation system) and flags over-capacity dates. Verified live with a synthetic 2-rooms-committed-vs-1-available case.
Voucher generation	DONE	New supplier-facing Service Voucher PDF per booking — states the trip is prepaid, lists the day-by-day plan and assigned guide/vehicle, includes emergency contacts.
Operations calendar	DONE	New month-view calendar of confirmed departures and reminders due, with inline guide/vehicle assignment from each day's detail panel.
Departure management	DONE	Calendar plus a new Departure Manifest — every departure on one date in a single printable document — plus an Operations Dashboard alert for any departure in the next 30 days missing a guide or vehicle.
Emergency/incident handling	DONE	Two pieces: admin-editable Emergency Contacts (shown on every voucher) and a real incident log (type, severity, resolution tracking, optionally linked to a booking), surfaced on the Operations Dashboard and linked from the calendar.

3. Business Workflow

The core pipeline (lead → quote → booking → reminders → self-service tracking) was already fully supported and untouched. The gaps were later stages: operations planning, travel execution, customer review, and repeat-sales automation.

Stage / Finding	Status	Detail
Lead capture → booking + payment	N/A	Already fully supported before this work; not touched.
Operations planning (no manifest/rostering/vouchers)	DONE	Closed by the Operations Management build above — manifest, guide/vehicle rostering, and vouchers all now exist.
Travel execution (no in-trip tooling)	PARTIAL	A computed Trip Status (Upcoming/In Progress/Completed), derived from travel date + duration with no separate field to drift out of sync, now shows on Bookings and a live count on the Operations Dashboard. This is visibility, not day-by-day in-trip tooling — named as a partial fix, not a complete one.

Stage / Finding	Status	Detail
Customer review — no capture anywhere	DONE	New public review/NPS submission (linked from the post-trip email) plus admin moderation. Verified end to end including duplicate-submission handling.
Repeat sales — no automated win-back flow	PARTIAL	A real 5th automated reminder type now exists: a 6-months-after-travel email, using the same infrastructure as the existing deposit/balance/departure/post-trip reminders. It checks at send time — not when scheduled — whether the guest already rebooked, and silently cancels itself if so; verified this check directly. This automates one win-back nudge, not a full points/discount loyalty program — an informational tier badge was added separately to the customer list, but no real points system exists.

4. Code Quality

Finding	Status	Detail
SMTP setup duplicated 6 times	DONE	3 of the 6 copies were in files confirmed entirely dead and deleted outright; the other 2 live call sites were refactored onto the one shared Mailer::sendRow()/queueRaw() path.
A dead file and two dead mail classes	DONE	api/mailer.php, BookingConfirmationMail.php, CustomSafariAckMail.php — confirmed zero callers, then deleted.
8 model methods are dead code	DONE	Re-verified individually (the first automated pass had false positives and was discarded) — 10 methods across 4 files turned out to be genuinely dead, including 2 found during verification that weren't in the original list. A whole model class (TeamMember) was deleted since its only method was one of them. Two methods that looked similarly unused were deliberately kept because a real test suite exercises them.
Client-side JS duplicates the server pricing calculator	PARTIAL	The audit's own recommendation was to accept the duplication as a UX tradeoff but add an automated test to catch drift. That test now exists: it extracts the real, deployed JavaScript function out of the live admin page (not a hand-copied duplicate) and runs it under Node against the PHP implementation for 9 dates including season boundaries. Verified the test actually catches drift by deliberately breaking the JS, watching it fail with a clear diagnostic, and restoring it. The underlying duplication itself is unchanged, by design.

Finding	Status	Detail
Cross-table collation mismatch	N/A	Re-checked live: every table is already utf8mb4_unicode_ci. Finding was already stale before this work began.
Naming, error handling, TODO hygiene	N/A	Already confirmed clean in the original audit; not touched.

5. Database

Finding	Status	Detail
PARK_FEES config vs DB — values had drifted	DONE	The fix here isn't patched numbers — it's removing the duplication entirely. Investigation found PARK_FEES, SEASONAL_RATES and ACTIVITY_PRICES were only ever read as a fallback inside the now-deleted QuotationEngine.php, making all three fully unreachable dead code, not a rarely-triggered risk. Removed, along with 4 more config constants confirmed dead for the same reason (VEHICLE_TYPES, GUIDE_LANGUAGES, MEAL_PLAN_RATES, CONSERVATION_FEE).
SEASONAL_RATES / ACTIVITY_PRICES duplication	DONE	Eliminated by the same removal — see above.
Untracked recent migrations	DONE	One migration (2026_09_package_tiers_and_costing.sql) had been applied to the live database earlier this session but never recorded in schema_migrations. Registered.
package_variants — scaffolded, 0 rows, unused	DONE	This table was created this session for a “multiple pricing tiers per itinerary” feature that was never built — packages already represent tiers as separate catalog rows. Confirmed zero references, dropped, with the migration recorded for history.
accommodation_seasonal_rates — scaffolded, unused	OPEN	Predates this work. Left alone — not this session's schema to unilaterally remove.
agent_targets — scaffolded, unused	OPEN	Predates this work; superseded by using admin_users.target_monthly for the new Agent Performance dashboard instead, a deliberately simpler choice. Left in place rather than dropped.
email_templates — 0 custom rows saved	N/A	Not broken — the admin UI works, it's simply unused because no admin has customized a template yet.

Also verified as part of this pass, not from the original findings list: 31 foreign keys now exist (up from 23 at audit time, from this session's new tables) with zero orphaned rows across all of them; collation stayed consistently utf8mb4_unicode_ci on every table added this session.

6. Performance & Known Bugs

Finding	Status	Detail
admin/guide.php — confirmed live PHP warning	DONE	The guide document wasn't missing, it was in the wrong folder (admin/ instead of the project root the code looked in). Moved it, and added a new section documenting the roughly 13 admin pages built this session that the guide previously had no record of.
poster_maker.php's AI Caption — confirmed broken	DONE	Was calling the Anthropic API directly from the browser with no key — guaranteed to fail every time, and unsafe even with one added client-side. Built a real server-side proxy (auth + CSRF protected, rebuilds the prompt from real database data rather than trusting the client) and a proper API-key config slot. Verified it now fails with an honest “not configured” message instead of a silent dead end.
N+1 query on the public Packages page	DONE	Was running one itinerary query per package inside a loop. Replaced with a single batched query. Verified identical output, zero warnings.
13 admin lists with no pagination	PARTIAL	Table sizes checked and confirmed unchanged (6–60 rows across the board) — full pagination UI would be unused complexity for zero present benefit. Instead added a LIMIT 200 safety net to every one of the 13 original queries plus 5 more found in pages built this session, directly closing the “no safety net if data grows” risk the audit actually named, without the maintenance cost of unused pagination.
No caching layer	OPEN	Deliberately not built — the original audit itself rated this “not urgent at current traffic/data volume” (largest table 967 rows), and nothing about that has changed.
Admin dashboard runs 17–30 unbatched queries	OPEN	Deliberately not touched, same reasoning — audit rated this low-urgency at current scale.
Only 1 of 27 sampled <img> tags sets width/height	OPEN	Not addressed. Real but purely cosmetic (layout shift), and getting correct per-image dimensions without guessing would mean inspecting each file individually — didn't want to rush that across many files.

7. Security

Every category the original audit checked (CSRF, SQL injection, file upload, secrets, RBAC, rate limiting, session security) had zero gaps. None of that was regressed — but the original audit predates roughly 73 changed files and ~6,000 lines of new code, none of which had ever been reviewed. That review was done directly, not assumed clean by association with the original result.

Check	Status	Detail
Auth on every new admin page	DONE	All 14 new admin pages call AuthMiddleware::requireAdmin(); the 2 pages exposing cross-agent/financial data additionally gate on isAdminRole().
CSRF on every new POST handler	DONE	POST-branch count matched exactly against CsrfMiddleware::validateOrDie() call count across every new/changed admin page — no gaps.
New public-facing endpoint (review submission)	DONE	Full stack confirmed: rate limiting, CSRF, honeypot, input sanitization, prepared statements, and correct output escaping on every reflected value.
SQL injection	DONE	Zero raw string-concatenation of user input into SQL anywhere in the reviewed diff; the one interpolated value (a date) is both regex-validated and properly quoted.
XSS / output escaping	DONE	Every free-text field (names, descriptions, notes, comments) confirmed passed through htmlspecialchars(); flagged-looking unescaped outputs were manually checked and are all integer/numeric columns, safe by type.
AI-generated content rendering	DONE	Renders via .textContent, never .innerHTML — model output cannot execute as markup even in principle.
New cost-abuse risk (found during this review)	DONE	The AI Caption fix itself introduced a real, unmitigated gap: no rate limit on an endpoint that calls a paid external API, meaning a compromised admin session could run up real costs. Added a 20/hour cap; verified live — 21st request in an hour correctly returns 429.
Encryption at rest	OPEN	Cannot be verified or fixed from inside the application — depends on the hosting provider's storage layer. Documented in the Admin Guide with the concrete next step (confirm directly with Hostinger support) rather than left silently unaddressed.
Blanket API gateway rate limiting	OPEN	Every public POST endpoint already has its own per-IP limit. A single gateway-level throttle in front of all API traffic is normally a reverse-proxy/WAF concern, not application code — deliberately not bolted on speculatively with no specific abuse pattern driving it.

Items That Are Your Call, Not the Codebase's

The 6 original audit PDFs are now stale OPEN

Audit_Report.pdf, System_Architecture.pdf, Database_Architecture.pdf, Security_Audit_Report.pdf, Enterprise_Upgrade_Roadmap.pdf and Master_Technical_Specification.pdf all document gaps that this report shows have since been closed or changed. This report is written to stand alongside them as the current picture, not to replace them — whether to regenerate, archive, or delete the originals is a documentation-management decision, not a code fix.

Homepage testimonials appear to be fabricated OPEN

views/home.php has three hardcoded guest quotes (“Rebecca & James T.”, “Marco & Sofia B.”, “Christine L.”) presented as real reviews, with no review-capture system existing anywhere in the codebase before this session — as far as can be verified, they aren't backed by real submissions. A genuine review system now exists and could supply real replacements once reviews come in. This wasn't touched — it's marketing copy, and displaying fabricated testimonials as genuine carries real reputational and, in some jurisdictions, legal risk, which makes it worth flagging clearly rather than silently editing or silently leaving alone.

Closing Note

Every “DONE” verdict in this report corresponds to a specific code change, verified against live data during the session it was made — not inferred, not assumed, and not claimed without a test. Every “PARTIAL” or “OPEN” verdict states the specific remaining gap and the reason it wasn't closed, rather than being left ambiguous. Where a decision carried real financial or reputational risk — multi-currency charging, a specific loyalty discount amount, dropping database tables, homepage marketing copy — the choice was either deliberately conservative or handed back explicitly rather than made unilaterally.

Report generated 20 September 2026 · Safari Zangu Ventures · covers all work performed in this engagement